

Risk Assessment and Management Methods

Dr. Ramokapane



Bristol Cyber Security Group

Elements of Risk

Vulnerability

Threat

Likelihood

Impact

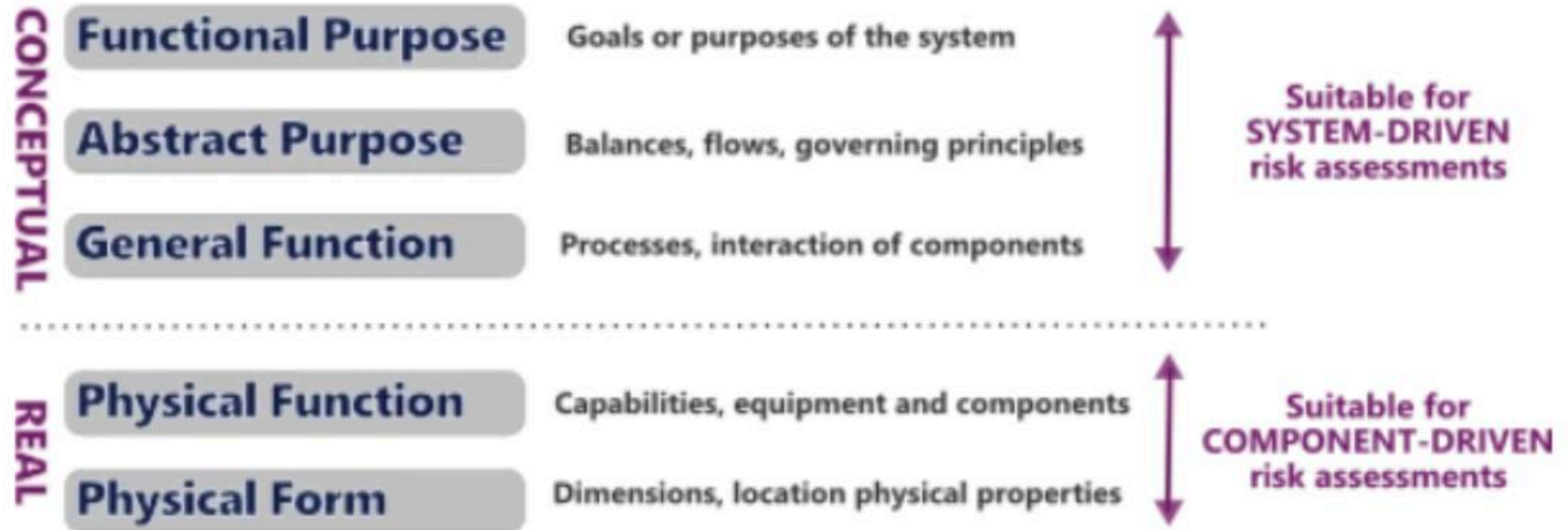
Component-driven

- Analysing the risks faced by individual technical components.
- Deconstructing less complex systems, with well-understood connections between component parts.
- Working at levels of abstraction where a system's physical function has already been agreed amongst stakeholders.

System-driven

- Exploring security breaches which emerge out of the complex interaction of many parts of your system.
- Establishing system security requirements before you have decided on the system's exact physical design.
- Bringing together multiple stakeholders' views of what a system should and should not do (e.g., safety, security, legal views).
- Analysing security breaches which cannot be tracked back to a single point of failure.

Component-driven vs. System-driven



Some Component-driven methods

ISO/IEC 27005:2018

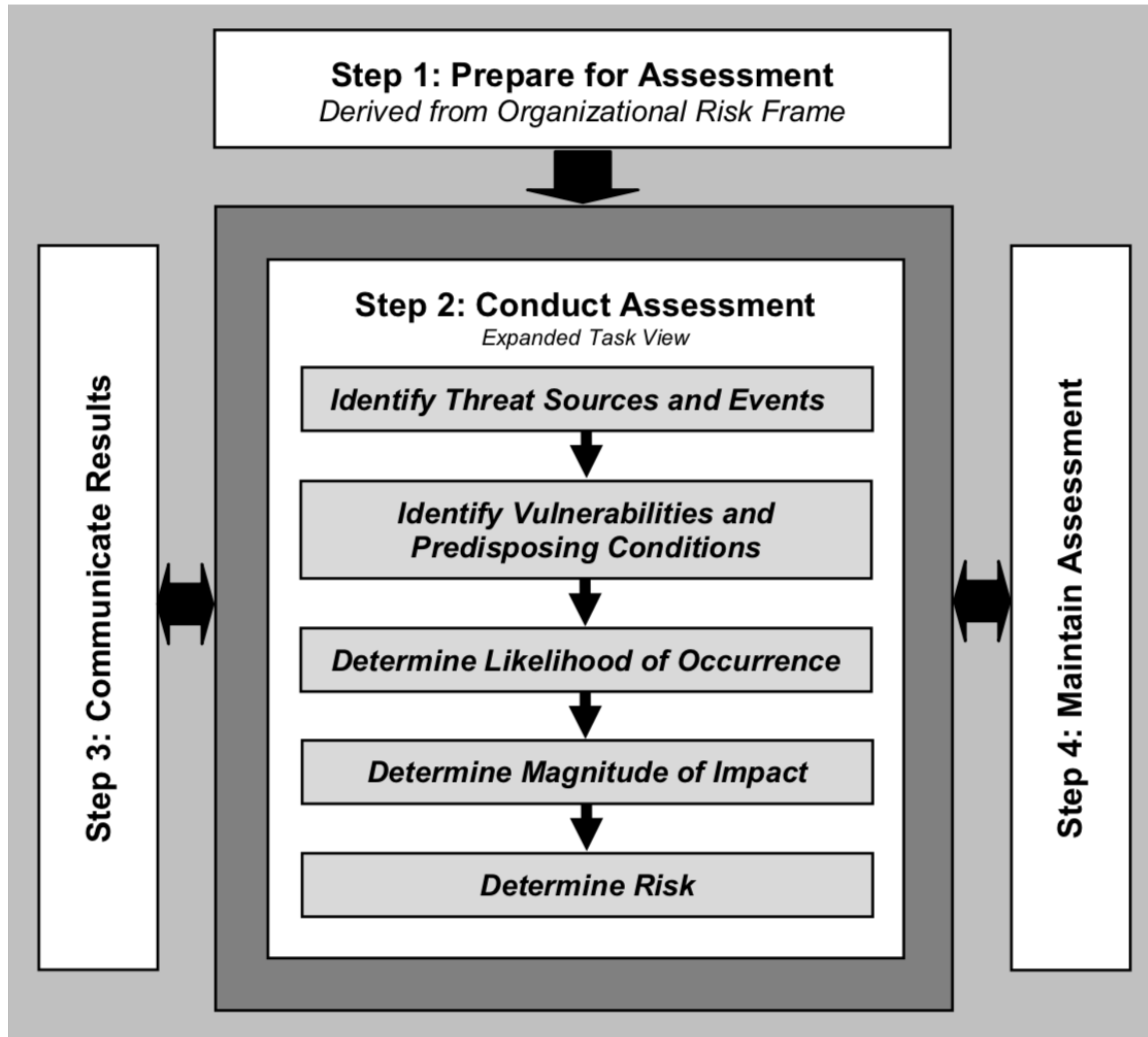
NIST SP800-30/39

IRAM 2

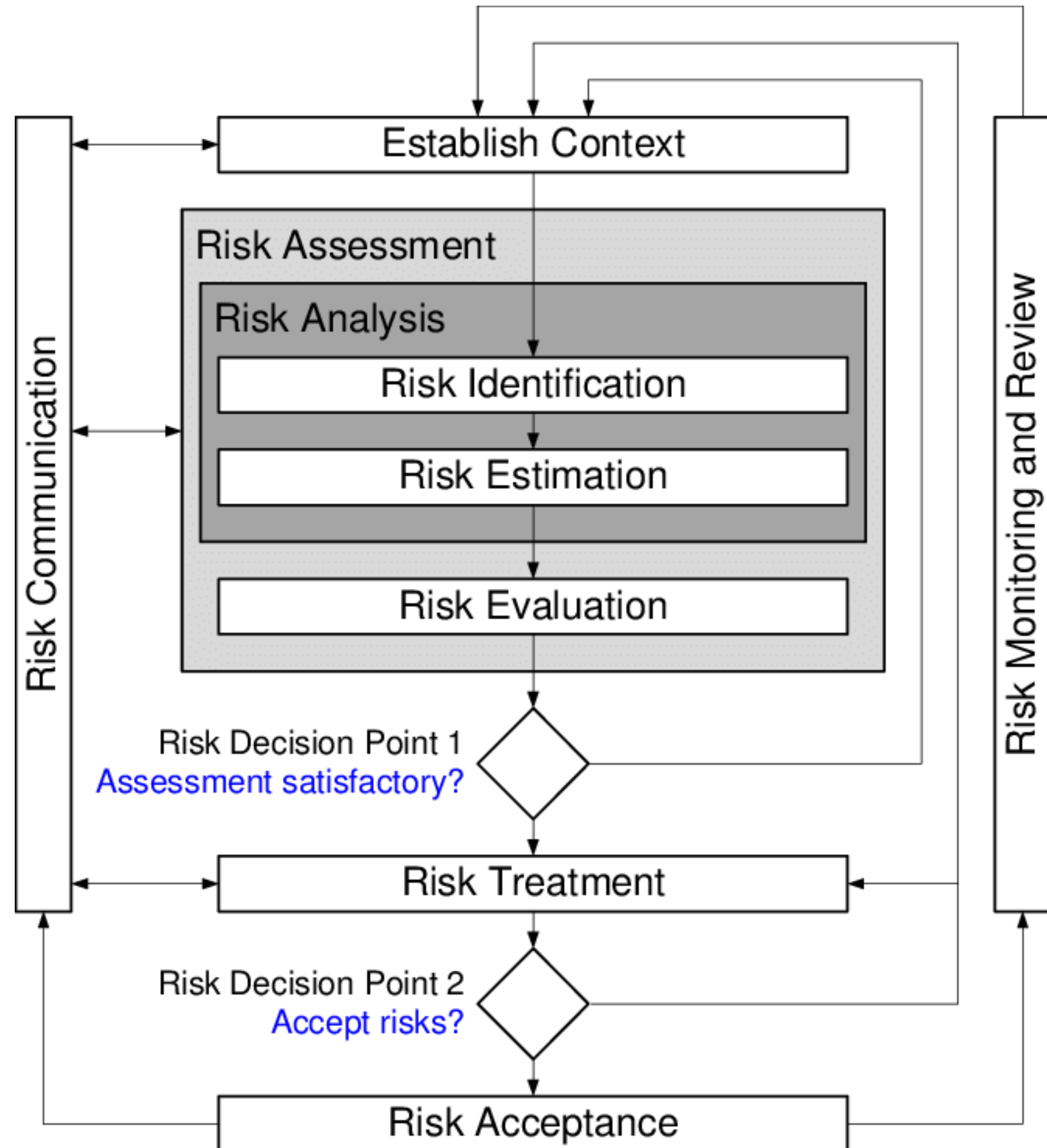
FAIR

Octave Allegro

NIST SP 800-30



ISO/IEC 27005



ISO/IEC 27005

vs.

NIST SP 800-30

Socio-technical

- Covers people, process and technology.
- Not prescriptive in assessment and management method (i.e. other methods could be used to manage risk) but covers threats, vulnerabilities, and impacts.
- Intended to target higher level management and decision makers.
- Clear focus on people internal and external

Technology-driven

- Focused on technical risk management of IT systems with prescriptive approach.
- Includes threats, vulnerabilities, likelihood and impact
- Also control monitoring and compliance verification.
- People not considered as a core organisational asset.
- Very US-centric

Some System-driven methods

Systems-Theoretic Accident Model and Process (STAMP)

The Open Group Architectural Framework (TOGAF)

Dependency Modelling

SABSA

STAMP

Helps identify risks emerging from subsystem interactions (***Causality***)

An ensemble of methods used for modelling causation of accidents and hazards, developed at MIT

Based on systems thinking and involves:

- identification of system purpose, unacceptable losses, hazards, and constraints;
- development of a hierarchical control structure;
- identification of unsafe control actions;
- analysis of causal scenarios that lead to these unsafe control actions. This can be supplemented by a timeline or sequence of events.

TOGAF

Supports both component- and system-driven approaches.

Linked to architectural representation of the enterprise.

Encompasses all the business activities and capabilities, information, and technology that make up the entire infrastructure and governance activities of the enterprise.

If this extends into partners, suppliers, and customers, as well as internal business units, then the model can also encompass this aspect.

Qualitative approach.

Risk assessment and mitigation worksheets are then maintained as governance artefacts.

Business Continuity

What happens when attacks do succeed?

Incident Response

Recovery Planning

A systematic approach is key!

ISO/IEC 27035-1:2016

Plan and Prepare: including the definition of an incident management policy and establishing a team to deal with incidents.

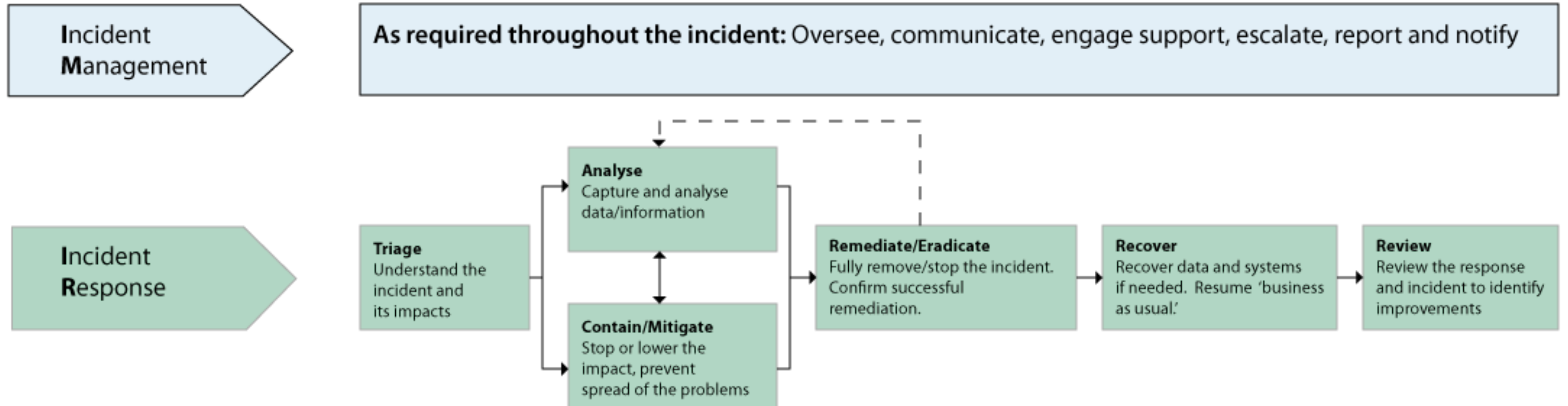
Detection and Reporting: observing, monitoring detecting and reporting of security incidents

Assessment and Decision: determining the presence (or otherwise) and associated severity of the incident and taking decisive action on steps to handle it.

Response: this may include forensic analysis, system patching, or containment and remediation of the incident.

Learning: a key part of incident management is learning – making improvements to the system defences to reduce the likelihood of future breaches.

NCSC Guidance



NCSC Guidance

Establish incident response capability: including funding and resources, either in-house or externally to manage incidents. This should include reporting incidents and managing any regulatory expectations.

Training: ensuring that necessary expertise is in place to manage incidents (e.g., forensic response and understanding of reporting expectations).

Roles: assign duties to individuals to handle incidents and empower them to respond to incidents in line with a clear action plan – and make sure this person is well known to people who may be likely to identify an incident.

Recovery: particularly for data and critical applications, make sure a backup is physically separated from the system – and test the ability to restore from backup.

Test: play out scenarios to test out the recovery plans; these should be refined based on practical and timely restoration under different attack scenarios.

NCSC Guidance (contd.)

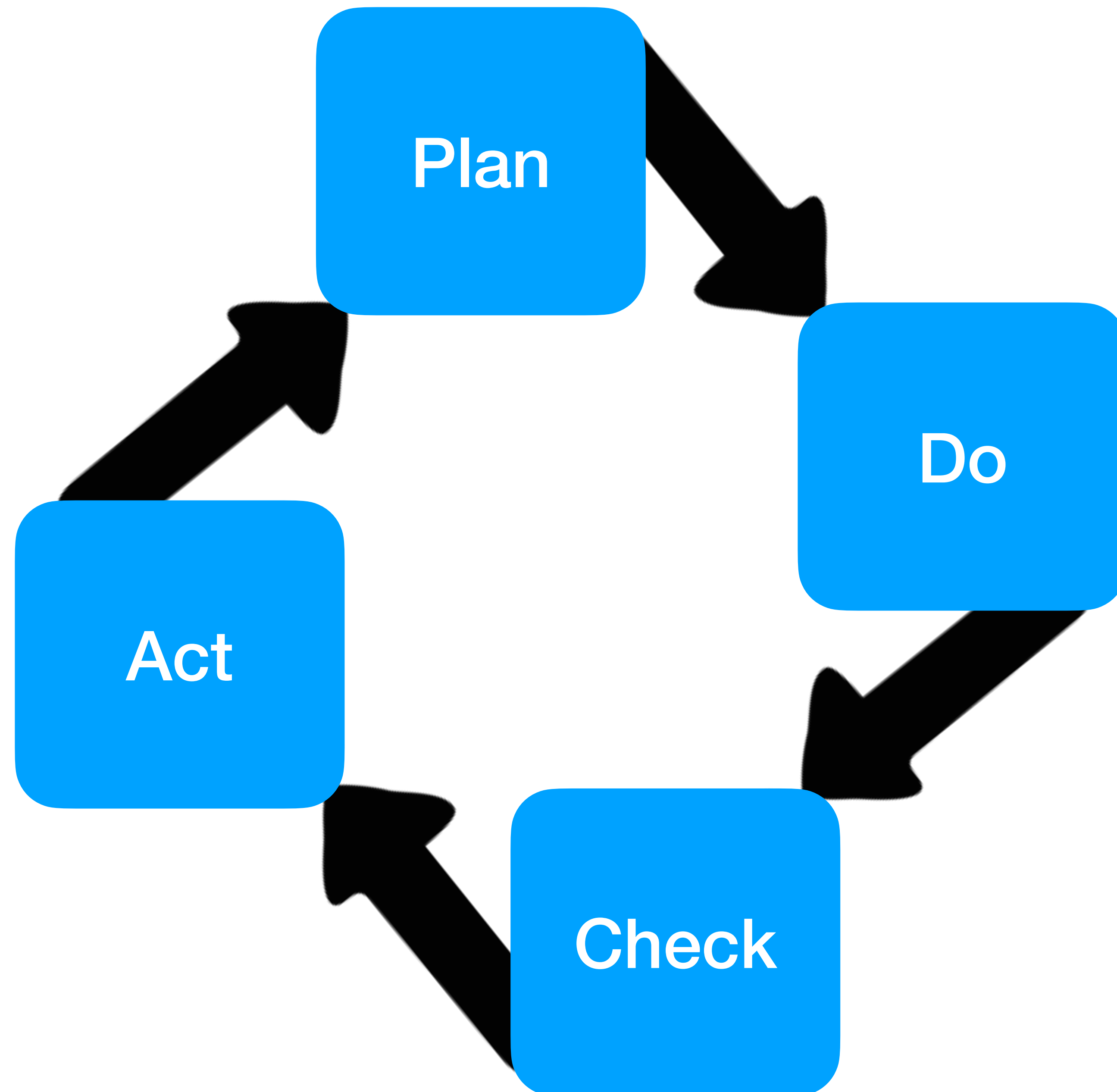
Report: ensure that information is shared with the appropriate personnel internally to improve risk management and security controls, plus externally to ensure legal or regulatory requirements are met.

Gather evidence: forensic response may be crucial following an incident – the preservation of evidence could be critical to legal proceedings or, at a minimum, understanding the events that led to the breach.

Develop: take note of the actions taken as part of the incident response. What worked and what did not? Where could the process be improved? As well as defences, the response plan may also benefit from refinement.

Awareness: continue to remind employees of their responsibilities and accountability regarding cyber security – remind them of how to report incidents and what to look out for.

Report: Cyber crime must be reported to relevant law enforcement agencies.



Further Reading

CyBOK - Risk Management and Governance Knowledge Area (on which this lecture is based): https://www.cybok.org/media/downloads/Risk_Management_Governance_v1.1.1.pdf